

Every request and every response

All 17 endpoints of the BFSI application. For each one: the method, the exact request, the successful response, and every error it can return — taken from the project's own controllers, services and security rules.

Before anything else

	Value
Base URL	http://localhost:8080
Every path starts with	/api
Format	JSON, in and out
Login	POST /api/auth/login — returns a token valid for 1 hour
Every other call needs	Authorization: Bearer <token>
Public, no token	POST /api/auth/login and GET /api/health

The three roles

Login	Role	May do
admin / admin123	ROLE_ADMIN	everything, including every DELETE
officer / officer123	ROLE_OFFICER	everything except DELETE
clerk / clerk123	ROLE_USER	read and write, but no loans and no DELETE

Responses any endpoint can return

Status	When	Body
401 Unauthorized	No Authorization header, or the token is invalid or expired	Empty, or the standard error body
403 Forbidden	Valid token, but the role is not allowed on this URL	Standard error body
404 Not Found	The id in the path does not exist	"message": "Customer 999 not found"
415 Unsupported Media Type	A POST or PUT sent without Content-Type: application/json	Standard error body
405 Method Not Allowed	Right URL, wrong method — e.g. GET on /api/auth/login	Standard error body
500 Internal Server Error	Something unexpected broke on the server	"message": "Unexpected error: ..."

The error body — the same shape every time

```
{ "timestamp": "2026-09-24T10:15:00",
  "status": 422,
  "error": "Unprocessable Entity",
  "message": "Customer already has 3 active loans",
  "errors": { } } // filled only when validation failed
```

Getting and using a token

POST /api/auth/login

Log in and receive a token

Who may call it: anyone — no token needed

Request

```
POST /api/auth/login HTTP/1.1
Host: localhost:8080
Content-Type: application/json
```

```
{ "username": "admin",
  "password": "admin123" }
```

Response — 200 OK

```
{ "token": "eyJhbGciOiJIUzI1NiJ9.eyJyb2xlcyI6WyJST0xFX0FETU10Il0s...",
  "username": "admin",
  "roles": ["ROLE_ADMIN"],
  "expiresInMs": 3600000 }
```

Other responses this endpoint can return

Status	When it happens	message in the body
401	Wrong username or wrong password	"Invalid username or password"
400	username or password missing from the body	"Validation failed" + errors map

Copy the token. Every other request in this document sends it as Authorization: Bearer <token>.

GET /api/auth/me

Who am I, according to my token

Who may call it: any logged-in role

Request

```
GET /api/auth/me HTTP/1.1
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9...
```

(no body)

Response — 200 OK

```
{ "username": "admin",
  "roles": ["ROLE_ADMIN"] }
```

Other responses this endpoint can return

Status	When it happens	message in the body
401	No token, or the token has expired	—

GET /api/health

Is the server up?

Who may call it: anyone — no token needed

Request

GET /api/health HTTP/1.1

(no body)

Response — 200 OK

```
{ "status": "UP",  
  "bank": "AMC Bank",  
  "branch": "1102",  
  "time": "2026-09-24T10:15:00.123" }
```

Use this to prove the server is running before blaming the React app.

2 • CUSTOMERS

Five endpoints — the full CRUD set

GET /api/customers

List customers, with optional filters

Who may call it: any logged-in role

Request

```
GET /api/customers HTTP/1.1
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9...

# variations:
GET /api/customers?city=Bangalore
GET /api/customers?search=anita      # matches name or email
```

Response — 200 OK

```
[ { "customerId": 101, "name": "Anita Rao", "email": "anita@example.com",
  "city": "Bangalore", "panNumber": "ABCDE1234F", "accountCount": 2 },
  { "customerId": 102, "name": "Vikram Shah", "email": "vikram@example.com",
    "city": "Mumbai", "panNumber": "BCDEF2345G", "accountCount": 1 } ]
```

Other responses this endpoint can return

Status	When it happens	message in the body
200 with []	No customer matches the filter — an empty list, not a 404	—
401	No token	—

search wins over city. If both are sent, the service runs the search and ignores the city.

GET /api/customers/{id}

One customer, with accounts and loans

Who may call it: any logged-in role

Request

```
GET /api/customers/101 HTTP/1.1
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9...
```

(no body)

Response — 200 OK

```
{ "customerId": 101, "name": "Anita Rao", "email": "anita@example.com",
  "city": "Bangalore", "panNumber": "ABCDE1234F", "accountCount": 2,
  "accounts": [ { "accountId": 1, "accountNumber": "AC5001", "accountType": "SAVINGS",
    "balance": 52000.0, "openedOn": "2026-01-12",
    "customerId": 101, "customerName": "Anita Rao" } ],
  "loans": [ { "loanId": 9001, "loanType": "HOME", "principalAmount": 500000.0,
    "interestRate": 8.4, "tenureMonths": 240, "emi": 4307.52,
    "sanctionedOn": "2026-09-24", "customerId": 101 } ] }
```

Other responses this endpoint can return

Status	When it happens	message in the body
404	No customer with that id	"Customer 999 not found"
401	No token	—

This is the only customer endpoint that returns the accounts and loans. The list endpoint returns accountCount only.

POST**/api/customers****Create a customer***Who may call it: any logged-in role*

Request

```
POST /api/customers HTTP/1.1
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9...
Content-Type: application/json
```

```
{ "name": "Kiran Prasad",
  "email": "kiran@example.com",
  "city": "Bangalore",
  "panNumber": "EFGHI5678J" }
```

Response — 201 Created

```
{ "customerId": 105, "name": "Kiran Prasad", "email": "kiran@example.com",
  "city": "Bangalore", "panNumber": "EFGHI5678J", "accountCount": 0 }
```

Other responses this endpoint can return

Status	When it happens	message in the body
400	name under 3 or over 60 characters, email not an email, city blank, PAN not ABCDE1234F	"Validation failed" + one entry per bad field
409	That email already belongs to a customer	"A customer with email kiran@example.com already exists"
401	No token	—

The request has no customerId — the server generates it. Sending one is simply ignored.

PUT /api/customers/{id}

Replace a customer's details

Who may call it: any logged-in role

Request

```
PUT /api/customers/101 HTTP/1.1
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9...
Content-Type: application/json
```

```
{ "name": "Anita R Rao",
  "email": "anita.rao@example.com",
  "city": "Mysore",
  "panNumber": "ABCDE1234F" }
```

Response — 200 OK

```
{ "customerId": 101, "name": "Anita R Rao", "email": "anita.rao@example.com",
  "city": "Mysore", "panNumber": "ABCDE1234F", "accountCount": 2 }
```

Other responses this endpoint can return

Status	When it happens	message in the body
400	Same validation rules as create	"Validation failed" + errors map
404	No customer with that id	"Customer 999 not found"
409	That email belongs to a different customer	"Email x@y.com belongs to another customer"
401	No token	—

PUT replaces every field. Sending only the name blanks the rest — and fails validation first.

DELETE /api/customers/{id}

Delete a customer

Who may call it: *ROLE_ADMIN* only

Request

```
DELETE /api/customers/105 HTTP/1.1
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9...
```

(no body)

Response — 204 No Content

(no body at all – the status is the whole answer)

Other responses this endpoint can return

Status	When it happens	message in the body
403	Logged in as officer or clerk	"Your role is not allowed to perform this action"
404	No customer with that id	"Customer 999 not found"
422	One of their accounts still holds money	"Customer still holds a balance - close the accounts first"
401	No token	—

3 • ACCOUNTS

Six endpoints — opening, money movement, closing

GET /api/accounts

List accounts

Who may call it: any logged-in role

Request

```
GET /api/accounts HTTP/1.1
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9...
```

```
# only one customer's accounts:
GET /api/accounts?customerId=101
```

Response — 200 OK

```
[ { "accountId": 1, "accountNumber": "AC5001", "accountType": "SAVINGS",
  "balance": 52000.0, "openedOn": "2026-01-12",
  "customerId": 101, "customerName": "Anita Rao" } ]
```

Other responses this endpoint can return

Status	When it happens	message in the body
200 with []	That customer has no accounts	—
401	No token	—

GET /api/accounts/{id}

One account

Who may call it: any logged-in role

Request

```
GET /api/accounts/1 HTTP/1.1
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9...
```

(no body)

Response — 200 OK

```
{ "accountId": 1, "accountNumber": "AC5001", "accountType": "SAVINGS",
  "balance": 52000.0, "openedOn": "2026-01-12",
  "customerId": 101, "customerName": "Anita Rao" }
```

Other responses this endpoint can return

Status	When it happens	message in the body
404	No account with that id	"Account 99 not found"
401	No token	—

POST /api/accounts

Open an account

Who may call it: any logged-in role

Request

```
POST /api/accounts HTTP/1.1
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9...
Content-Type: application/json

{ "customerId": 101,
  "accountType": "SAVINGS",           // or CURRENT
  "balance": 25000 }
```

Response — 201 Created

```
{ "accountId": 3, "accountNumber": "AC5003", "accountType": "SAVINGS",
  "balance": 25000.0, "openedOn": "2026-09-24",
  "customerId": 101, "customerName": "Anita Rao" }
```

Other responses this endpoint can return

Status	When it happens	message in the body
400	customerId missing, accountType not SAVINGS or CURRENT, balance negative	"Validation failed" + errors map
404	No customer with that customerId	"Customer 999 not found"
422	A SAVINGS account opened with less than 1,000	"A savings account needs an opening balance of at least 1000.0"
401	No token	—

accountNumber is generated by the server as AC + (5000 + id). Sending one is ignored.

PATCH /api/accounts/{id}/deposit

Pay money in

Who may call it: any logged-in role

Request

```
PATCH /api/accounts/1/deposit HTTP/1.1
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9...
Content-Type: application/json
```

```
{ "amount": 5000 }
```

Response — 200 OK

```
{ "accountId": 1, "accountNumber": "AC5001", "accountType": "SAVINGS",
  "balance": 57000.0, "openedOn": "2026-01-12",
  "customerId": 101, "customerName": "Anita Rao" }
```

Other responses this endpoint can return

Status	When it happens	message in the body
422	amount is zero or negative	"Deposit amount must be greater than zero"
404	No account with that id	"Account 99 not found"
401	No token	—

PATCH, not PUT: it changes one thing about the account rather than replacing it.

PATCH /api/accounts/{id}/withdraw

Take money out

Who may call it: any logged-in role

Request

```
PATCH /api/accounts/1/withdraw HTTP/1.1
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9...
Content-Type: application/json
```

```
{ "amount": 1500 }
```

Response — 200 OK

```
{ "accountId": 1, "accountNumber": "AC5001", "accountType": "SAVINGS",
  "balance": 55500.0, "openedOn": "2026-01-12",
  "customerId": 101, "customerName": "Anita Rao" }
```

Other responses this endpoint can return

Status	When it happens	message in the body
422	amount is zero or negative	"Withdrawal amount must be greater than zero"
422	A SAVINGS account would go below zero	"Insufficient balance"
404	No account with that id	"Account 99 not found"
401	No token	—

A CURRENT account is allowed to go negative — the overdraft limit is not enforced in this version. Worth pointing out as the gap a student could close.

DELETE`/api/accounts/{id}`

Close an account

Who may call it: ROLE_ADMIN only

Request

```
DELETE /api/accounts/3 HTTP/1.1
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9...
```

(no body)

Response — 204 No Content

(no body)

Other responses this endpoint can return

Status	When it happens	message in the body
403	Logged in as officer or clerk	"Your role is not allowed to perform this action"
422	The balance is not exactly zero	"Account AC5003 still has a balance of 25000.0"
404	No account with that id	"Account 99 not found"
401	No token	—

Two endpoints — and the strictest rules in the application

POST /api/loans

Sanction a loan

Who may call it: `ROLE_ADMIN` or `ROLE_OFFICER`

Request

```
POST /api/loans HTTP/1.1
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9...
Content-Type: application/json

{ "customerId": 101,
  "loanType": "HOME",           // HOME, CAR or PERSONAL
  "principalAmount": 500000,
  "interestRate": 8.4,
  "tenureMonths": 240 }
```

Response — 201 Created

```
{ "loanId": 9001, "loanType": "HOME",
  "principalAmount": 500000.0, "interestRate": 8.4, "tenureMonths": 240,
  "emi": 4307.52,              // calculated by the server
  "sanctionedOn": "2026-09-24", "customerId": 101 }
```

Other responses this endpoint can return

Status	When it happens	message in the body
400	loanType not one of the three, principal under 10,000, rate outside 1–30, tenure outside 6–360	"Validation failed" + errors map
403	Logged in as clerk (<code>ROLE_USER</code>)	"Your role is not allowed to perform this action"
404	No customer with that customerId	"Customer 999 not found"
422	The customer already has three loans	"Customer already has 3 active loans"
422	Their accounts hold less than 10% of the principal	"Customer must hold at least 10% of the loan amount across accounts"
401	No token	—

400 or 422? 400 means the request was malformed — a number out of range. 422 means the request was perfectly formed but a banking rule said no. Teaching that distinction is the point of this endpoint.

GET /api/loans/customer/{customerId}

All loans of one customer

Who may call it: *ROLE_ADMIN* or *ROLE_OFFICER*

Request

GET /api/loans/customer/101 HTTP/1.1
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9...

(no body)

Response — 200 OK

```
[ { "loanId": 9001, "loanType": "HOME", "principalAmount": 500000.0,
  "interestRate": 8.4, "tenureMonths": 240, "emi": 4307.52,
  "sanctionedOn": "2026-09-24", "customerId": 101 } ]
```

Other responses this endpoint can return

Status	When it happens	message in the body
200 with []	The customer exists but has no loans	—
403	Logged in as clerk	"Your role is not allowed to perform this action"
404	No customer with that id	"Customer 999 not found"
401	No token	—

One endpoint that feeds the whole dashboard

GET /api/reports/summary

Every dashboard number in one call

Who may call it: any logged-in role

Request

```
GET /api/reports/summary HTTP/1.1
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9...
```

(no body)

Response — 200 OK

```
{ "customers": 128,
  "accounts": 211,
  "activeLoans": 37,
  "totalDeposits": 42150000.0,
  "loansByType": [ { "label": "HOME", "value": 12 },
                  { "label": "CAR", "value": 15 },
                  { "label": "PERSONAL", "value": 10 } ],
  "depositsByCity": [ { "label": "Bangalore", "value": 21500000.0 },
                    { "label": "Mumbai", "value": 12300000.0 } ] }
```

Other responses this endpoint can return

Status	When it happens	message in the body
200 with zeros	A fresh, empty database — not an error	—
401	No token	—

One call, not four. The label/value pairs are already in the shape a Recharts bar chart expects.

All 17 endpoints on one page

Method	Path	Success	Can also return	Who
POST	/api/auth/login	200	400 · 401	anyone
GET	/api/auth/me	200	401	any role
GET	/api/health	200	—	anyone
GET	/api/customers	200	401	any role
GET	/api/customers/{id}	200	401 · 404	any role
POST	/api/customers	201	400 · 401 · 409	any role
PUT	/api/customers/{id}	200	400 · 401 · 404 · 409	any role
DELETE	/api/customers/{id}	204	401 · 403 · 404 · 422	ADMIN
GET	/api/accounts	200	401	any role
GET	/api/accounts/{id}	200	401 · 404	any role
POST	/api/accounts	201	400 · 401 · 404 · 422	any role
PATCH	/api/accounts/{id}/deposit	200	401 · 404 · 422	any role
PATCH	/api/accounts/{id}/withdraw	200	401 · 404 · 422	any role
DELETE	/api/accounts/{id}	204	401 · 403 · 404 · 422	ADMIN
POST	/api/loans	201	400 · 401 · 403 · 404 · 422	ADMIN, OFFICER
GET	/api/loans/customer/{id}	200	401 · 403 · 404	ADMIN, OFFICER
GET	/api/reports/summary	200	401	any role

Reading the pattern

- GET never has a body and never changes anything. Safe to repeat.
- POST creates and answers 201. Repeating it creates a second thing — or a 409.
- PUT replaces the whole record and answers 200. Repeating it is harmless.
- PATCH changes one part — here, a balance. Repeating it deposits twice.
- DELETE answers 204 with no body at all. The second attempt gives 404.
- 400 is a malformed request; 422 is a well-formed request refused by a banking rule.
- 401 is 'I don't know you'; 403 is 'I know you, and no'.